

基于生成论的网络安全分析能力调度系统

第 1 卷：防御方理论

李龙胜

2026 年 6 月 16 日

这是给防御者的手册。

1.1 告诉你最优分析率怎么算。

1.2 教你零数学基础落地。

1.3 为你展示整套理论的数学骨架。

选择你需要的深度，跳过你不需要的严谨。

摘要

第 1 卷聚焦防御方如何用生成论的择优公式裁定告警的最优分析率。1.1 建立告警分级裁定的数学模型，定义漏报损失和分析成本，推导最优分析率的解析条件，给出完整的算法流程和伪代码。1.2 提供面向一线工程师的实施指南，包括台账建立、参数估算、动态反馈规则和快速启动方案。1.3 将整个安全运营过程形式化为生成步系统的实例，验证四条公设的满足性，并证明贪心最优性定理。全部内容保持 CC BY 4.0 协议公开。

目录

1	1.1 问题与模型：告警洪流中的最优选择	1
1.1	问题描述	1
1.2	系统抽象	1
1.3	成本函数	2
1.4	最优分析率（线性模型）	2
1.5	非线性扩展（进阶）	3
1.6	算法流程	3
1.7	伪代码	4
1.8	诚实标注	4
2	1.2 实施指南	4
2.1	核心思路：算一笔经济账	4
2.2	准备工作：建立成本台账	5
2.3	参数快速估算	5

2.4	每日人力分配	5
2.5	动态调节：让台账越跑越准	5
2.6	快速启动方案	6
2.7	常见问题	6
3	1.3 生成步系统实例化	6
3.1	状态空间	6
3.2	生成步：告警分析操作	6
3.3	记录成本函数	7
3.4	容量约束	7
3.5	贪心择优与最优分析率	7
3.6	公理满足性	7
3.7	与贪心最优性定理的对接	7
3.8	诚实标注	8

1 1.1 问题与模型：告警洪流中的最优选择

1.1 问题描述

现代安全运营中心每天产生海量告警。一个中型企业每日告警量可达 3 万条以上，而负责分析的一线分析师通常只有 3 到 5 人。传统做法只有两种：要么逐条分析，但人力完全无法承受；要么按经验规则抽样，但随意舍弃可能导致真正的攻击信号被淹没。

生成论的最佳记录粒度理论为这个问题提供了第三种选择：不是完整记录一切，也不是随意舍弃，而是通过择优公式，自动裁定每类告警的“最优分析率”。系统在漏报损失和分析成本之间寻找最低总成本的平衡点。

1.2 系统抽象

整个安全运营过程被抽象为一个生成步系统：

- **状态空间**：当前安全态势，包括资产状态、已知漏洞、正在进行的攻击活动。
- **生成步**：对一条告警的分析操作，分为三类：
 - (1) 忽略——采样率 $r = 0$ ，不消耗人力，漏报风险最高。
 - (2) 自动分析——采样率 $r \in (0, 1)$ ，由 SOAR 剧本处理，消耗少量人力。
 - (3) 人工深度分析——采样率 $r = 1$ ，逐条分析，消耗大量人力，漏报风险最低。
- **记录成本**：包括状态偏差成本（漏报损失）和评估成本（分析耗时）。
- **容量上限**：每日可投入的总工时预算 C 。

1.3 成本函数

状态偏差成本 $V(r)$: 度量因分析率 r 不足而漏报攻击所造成的期望损失。当 $r = 1$ （完整分析）时， $V(1) = 0$ 。当 $r < 1$ 时，漏报概率为 $1 - r$ ，假设损失与该概率成正比：

$$V(r) = \alpha \cdot A \cdot (1 - r), \quad (1)$$

其中 A 是该类告警中攻击成功时的最大损失， α 是敏感度系数。

评估成本 $K(r)$: 度量以分析率 r 处理告警所需的人力成本。分析每一条告警需要平均工时 t ，分析师时薪为 s ，则：

$$K(r) = \kappa \cdot r, \quad (2)$$

其中 $\kappa = s \cdot t$ 是单条告警的单位分析成本。

总记录成本 $J(r)$:

$$J(r) = V(r) + K(r) = \alpha A(1 - r) + \kappa r. \quad (3)$$

1.4 最优分析率（线性模型）

系统需要选择 $r \in [0, 1]$ 使得总成本 $J(r)$ 最小。 $J(r)$ 是关于 r 的线性函数：

$$J(r) = \alpha A + (\kappa - \alpha A)r.$$

因此：

- 若 $\kappa < \alpha A$ （分析成本低于期望损失），最优分析率 $r^* = 1$ ——完整分析。
- 若 $\kappa > \alpha A$ （分析成本高于期望损失），最优分析率 $r^* = 0$ ——完全忽略。
- 若 $\kappa = \alpha A$ ， r^* 在 $[0, 1]$ 内任意。

大白话解释：

- 如果可能损失大于分析成本（ $\alpha A > \kappa$ ）：每条都要看（ $r^* = 1$ ）。
- 如果可能损失小于或等于分析成本（ $\alpha A \leq \kappa$ ）：完全忽略（ $r^* = 0$ ）。

1.5 非线性扩展（进阶）

真实安全运营中，攻击信号往往具有带宽特性——攻击手法变化越快，需要的采样率越高。引入信号采样的非线性模型更为精确。

设告警信号的有效带宽为 B ，信号的最大动态范围为 A 。当分析率 r 低于奈奎斯特频率时，产生混叠误差：

$$V(r) = \alpha A^2 \cdot \left(\frac{2B}{r} - 1 \right)^2, \quad r < 2B. \quad (4)$$

评估成本仍为 $K(r) = \kappa r$ 。

最优分析率 r^* 由方程

$$\frac{1 - r}{r^4} = \frac{\kappa}{2\beta} \quad (5)$$

在 $(0, 1]$ 内的唯一解决定，其中 $\beta = \alpha A^2 / (2B)^2$ 。在实际 SOC 部署中，可先使用线性模型快速裁定，随着历史数据的积累，逐步迁移至非线性模型。

1.6 算法流程

预处理与特征提取：对每条告警提取源 IP、目标 IP、端口、攻击类型、规则 ID、资产重要性、历史误报率等。

告警分类：根据攻击类型和目标资产重要性，将告警归入 K 个预定义类别。例如：

- 类别 1：高危漏洞利用（针对核心服务器）。
- 类别 2：中危漏洞扫描（针对普通服务器）。
- 类别 3：低危信息收集（端口扫描）。
- 类别 4：内部横向移动检测。

每类告警从台账中读取参数 A, B, α, κ 。

最优分析率计算：对每类告警 i ：

1. 计算 $\beta_i = \alpha_i A_i^2 / (2B_i)^2$ （若使用非线性模型）。
2. 求解方程 $\frac{1-r_i}{r_i^4} = \frac{\kappa_i}{2\beta_i}$ 得到 r_i^* 。
3. 若使用线性模型， $r_i^* = 1$ 若 $\kappa_i < \alpha_i A_i$ ，否则 $r_i^* = 0$ 。

配额分配与总工时约束：设第 i 类告警的预计日到达量为 N_i ，每条平均分析时间为 t_i 。所需总工时：

$$T = \sum_{i=1}^K r_i^* \cdot N_i \cdot t_i.$$

若 $T \leq C$ ，所有配额均被批准。若 $T > C$ ，按 β_i （漏报损失大、分析收益高的类别）从高到低排列，从最低 β_i 的类别开始依次减少 r_i^* （每次减少 0.05），直至 $T \leq C$ 。

实时裁定：对每条告警：

1. 查找其类别 i 及当前最优分析率 r_i^* 。
2. 生成随机数 $p \in [0, 1]$ 。
3. 若 $p \leq r_i^*$ ：
 - 若 $r_i^* \geq 0.8$ ，标记为人工深度分析。
 - 否则，标记为自动分析（由 SOAR 剧本处理）。
4. 若 $p > r_i^*$ ：标记为忽略。

自适应反馈：每周统计各类告警中真实攻击的发现率：

- 若某类告警漏报导致安全事件，人工干预将 A_i 乘以 2。
- 若某类告警连续四周零有效攻击，自动将 A_i 乘以 0.9。
- 重新计算 β_i 和 r_i^* 。

1.7 伪代码

1.8 诚实标注

命题	状态	层级
告警生成步系统抽象	抽象合理, 跨 SOC 适用性待验证	II (框架已建立)
线性成本模型下的最优分析率	解析解已给出, 边界条件明确	I (推导严格)
非线性成本模型下的最优分析率	方程已推导, 依赖信号带宽假设	II (定性正确, 参数需校准)
动态反馈调整 A 的规则	启发式规则已建立, 非从公设严格导出	III (启发式猜想, 待最优化证明)
告警分类的完备性	依赖专家经验, 可能存在未覆盖类型	II (框架完备, 分类需持续更新)

2 1.2 实施指南

2.1 核心思路：算一笔经济账

我们不是追求“每条都看”，也不是“凭经验挑着看”。而是用简单的数学逻辑，自动算出每类告警该花多少精力去查。

这个逻辑只有一句话：

分析成本高于可能损失，就少查；可能损失高于分析成本，就多查。

2.2 准备工作：建立成本台账

新建一张 Excel 表（或数据库表），包含以下字段：

字段	含义	示例值	如何获取
告警类别	攻击类型或规则名称	“永恒之蓝漏洞利用”	按 SIEM 规则分组
A	漏掉一条告警可能损失（元）	1000000	可参考攻防演练扣分表，后期自动修正
B	每天平均告警数量（条）	300	从日志统计
α	敏感度系数	1.0	初期设为 1，根据情况调整
t	分析一条告警耗时（小时）	0.02（约 1 分钟）	分析师记录平均处理时间
s	分析师时薪（元/小时）	100	公司薪酬数据

2.3 参数快速估算

- A (可能损失): 初期建议分三档——
 - 涉及核心服务器、数据库、域控的告警: $10^5 \sim 10^6$ 元。
 - 涉及普通服务器、终端、业务系统的告警: $10^3 \sim 10^4$ 元。
 - 已被 WAF/防火墙自动阻断的告警: $10^1 \sim 10^2$ 元。
- t (分析耗时): 让一线分析师记录一周内各类型告警的平均处理时间, 取分钟数除以 60。
- α (敏感度): 初期统一设 1.0。后续如果发现某类告警特别容易被利用, 可以手动调高。

2.4 每日人力分配

每天上午 8:00, 脚本自动统计各类告警的预计到达量 N_i (取前 7 天均值)。计算当天所需总工时:

$$T = \sum_{i=1}^K r_i^* \cdot N_i \cdot t_i.$$

若 T 超出当日可投入总工时 C , 则按以下优先级调整:

1. 优先保证 αA 最大的告警类别得到完整的分析率。
2. 降低 αA 最小的告警类别的分析率, 每次减少 0.1, 直到总工时不超过 C 。

调整后的分析率 $r_i^\dagger$ 即为当天该类别告警的实际抽样比例。

2.5 动态调节: 让台账越跑越准

每周进行一次复盘, 用实际数据修正初始估算。

触发“翻倍”机制: 如果某类告警漏报导致安全事件, 则手动将台账中该类的 A 值乘以 5。下周起, 该类的分析率会自动飙升。

触发“衰退”机制: 如果某类告警连续四周都生成过, 但分析师复查后全部是误报, 则将该类的 A 值乘以 0.9。下周起, 该类的分析率会自动下降。

定期审计: 每季度检查一次台账, 确认 A 和 t 的值是否仍然合理。

2.6 快速启动方案

如果您不想等系统全部搭建完成, 可以先用以下方式测试算法:

- (1) 选取过去一个月内出现频率最高的 10 类告警。
- (2) 在 Excel 中为这 10 类告警填好 A 和 t 的估计值 (其他参数用默认值)。
- (3) 用公式 $r^* = 1$ 若 $\alpha A > \kappa$, 否则 $r^* = 0$ 手算出最优分析率。
- (4) 比对过去一个月您的团队实际花了多少时间在这些告警上。
- (5) 如果算法建议“忽略”的告警类型恰好是您也觉得“看了也白看”的, 说明算法有效。

2.7 常见问题

这和设备的威胁评级有什么区别？设备评的是“这个攻击有多危险”，我们算的是“这个告警值不值得花时间去查”。一个高危告警如果每次都自动被阻断，查它就是浪费人力。

如果我漏掉了一条告警导致出事，谁负责？这套算法的逻辑是帮您把时间花在最可能出事的地方。如果出事，出事的告警一定是被算法标注为“低分析率”的——那您需要反思的是：为什么这个本该是高分分析率的告警，您当初给它标了低损失值？

需要什么样的技术栈？只需要三种东西：一张台账表（Excel 或 MySQL）、一个可以运行 Python 脚本的服务器、以及安全设备的数据接口。不需要机器学习，不需要大数据平台。

我的团队很小，这样做有意义吗？团队越小，越需要把力气用在刀刃上。小团队根本不可能处理所有告警。

3 1.3 生成步系统实例化

（本节将安全运营形式化为生成步系统，验证公设满足性。如果对数学严格性不感兴趣，可以跳过本节。）

3.1 状态空间

安全运营状态由两部分组成：安全态势和剩余分析能力。

定义 3.1 (安全运营状态). 设 $\mathcal{S}_{asset}$ 为资产安全态势空间， $\mathcal{R} \in [0, C]$ 为已消耗的工时累计量， C 为每日总工时预算。则安全运营状态为

$$s = (\mathcal{S}_{asset}, \mathcal{R}) \in \mathcal{S}_{SOC}.$$

3.2 生成步：告警分析操作

告警分析操作 U 属于三类之一：忽略、自动分析、人工深度分析。在实际裁定中，这三类通过分析率 $r \in [0, 1]$ 统一决定。

3.3 记录成本函数

记录成本由漏报损失和分析耗时组成：

$$R(s, U) = \begin{cases} \alpha_i A_i, & \text{若 } U = \text{忽略}, \\ \kappa_i^{\text{auto}} + \alpha_i A_i (1 - \eta_{\text{auto}}), & \text{若 } U = \text{自动}, \\ \kappa_i^{\text{manual}}, & \text{若 } U = \text{人工}. \end{cases}$$

当使用分析率 r_i 对整类告警裁定时，该类别期望记录成本为

$$J_i(r_i) = (1 - r_i) \alpha_i A_i + r_i \bar{\kappa}_i.$$

3.4 容量约束

每日累计消耗工时不得超过 C :

$$\sum_{i=1}^K r_i \cdot N_i \cdot t_i \leq C.$$

3.5 贪心择优与最优分析率

在容量约束不饱和时, 贪心择优给出的最优分析率为

$$r_i^* = \begin{cases} 1, & \text{若 } \alpha_i A_i > \bar{\kappa}_i, \\ 0, & \text{否则.} \end{cases}$$

饱和时按 β_i 降序削减。

3.6 公理满足性

本实例满足生成步系统的四条公理:

- **过程性:** 任何告警到达时, 至少可执行忽略操作。
- **记录性:** 任何分析操作均消耗不可逆的分析能力, 最小记录量 $R_{\min} = \min(\kappa_i, \alpha_i A_i) > 0$ 。
- **够用就行原则:** 每条告警的裁定遵循贪心择优。
- **观测自洽:** 成本函数由台账参数确定, 不同分析师使用相同台账时裁定结果一致。

3.7 与贪心最优性定理的对接

贪心最优性定理 (第 0 卷) 的条件在此实例中对应:

- **单调进展量** $f(s) =$ 分析师工作时数累积, 严格单调递增。
- **成本凸性:** 在忽略—自动—人工三级操作中, 记录成本对分析率 r 呈线性, 而高阶的 B 重标定成本引入了严格凸性, 使贪心路径最优。
- **成本分解:** $R = R_{\text{base}} + R_{\text{trans}}$, 满足定理条件。

因此, 安全运营告警分级裁定引擎是生成步系统的可靠实例, 贪心择优定理保证其最优性。

3.8 诚实标注

命题	状态	层级
安全运营 GS 实例的公理满足性	已逐条验证	I
最优分析率贪心择优的最优性	在容量不饱和时严格等价于全局最优; 饱和时在凸性假设下保持最优	II

文档信息：

- 作者：李龙胜
- 版本：v1.0（四卷体系重构第 1 卷）
- 许可：CC BY 4.0
- 前置依赖：第 0 卷

Algorithm 1 基于生成论的自动化告警分级裁定

Require: 告警流, 台账数据, 分析师时薪, 每日总工时预算 C

Ensure: 每条告警的分析动作 (忽略/自动/人工)

```
1: 初始化: 从数据库加载每类告警的  $A, B, \alpha, \kappa$ 
2: loop
3:   预处理: 解析告警, 提取特征
4:   分类: 将告警归入预定义类别
5:   for 每类告警  $i = 1$  to  $K$  do
6:      $\beta_i \leftarrow \alpha_i \cdot A_i^2 / (2B_i)^2$ 
7:     求解  $\frac{1-r_i}{r_i^4} = \frac{\kappa_i}{2\beta_i}$  得到  $r_i^*$  (或使用线性模型)
8:   end for
9:   预测当日各类告警到达量  $N_i$ 
10:   $T \leftarrow \sum_i r_i^* \cdot N_i \cdot t_i$ 
11:  if  $T > C$  then
12:    按  $\beta_i$  降序排列类别
13:    for 类别  $i$  从低  $\beta_i$  到高  $\beta_i$  do
14:      while  $T > C$  且  $r_i^* > 0$  do
15:         $r_i^* \leftarrow \max(0, r_i^* - 0.05)$ 
16:        重新计算  $T$ 
17:      end while
18:    end for
19:  end if
20:  for 每条告警 do
21:    取类别  $i$ ,  $r \leftarrow r_i^*$ 
22:     $p \leftarrow \text{random}(0, 1)$ 
23:    if  $p \leq r$  then
24:      if  $r \geq 0.8$  then
25:        标记: 人工深度分析
26:      else
27:        标记: 自动分析
28:      end if
29:    else
30:      标记: 忽略
31:    end if
32:  end for
33:  记录分析结果和攻击发现情况
34: end loop
35: 每周: 评估漏报事件, 若发生漏报则  $A_i \leftarrow 2A_i$ ; 若连续四周零有效攻击则  $A_i \leftarrow 0.9A_i$ 
36: 每周: 更新数据库中各类告警的  $A_i$ , 重新计算后续参数
```
